

LEARNING RESOURCE GUIDE
ISC2 CCSP: Certified Cloud Security Professional (Aug 2026) | Professional
Participant Workbook

Privacy Laws: Part 2 — FERPA, PIPEDA and India's DPDPA

1. Learning Objectives

By the end of this lecture, you will be able to:

- Explain FERPA's scope, the categories of protected student records, and the role of cloud vendors as school officials.
- Describe PIPEDA's consent-based framework and the additional obligations created by Quebec's Law 25.
- Outline the key provisions of India's DPDPA, including the data fiduciary and data principal concepts.
- Identify exam scenario cues that distinguish which privacy law applies in a given cloud deployment.
- Recognise the common thread of individual access rights and accountability across FERPA, PIPEDA, and the DPDPA.

2. Introduction

A university system in Ontario recently migrated its student information system to a cloud platform headquartered in the United States. The migration involved legal review teams from three jurisdictions simultaneously: US federal counsel assessed FERPA compliance for the cloud vendor relationship; Canadian federal privacy counsel reviewed PIPEDA obligations for cross-border data transfers; and Quebec's provincial team reviewed whether Law 25's additional requirements applied to a Quebec campus. No single privacy law governed the entire arrangement. The cloud contract required separate amendments to satisfy each framework.

This multi-framework reality is common in global cloud deployments. GDPR and HIPAA receive the most attention, but the CCSP exam requires familiarity with three additional frameworks: FERPA, which governs student records in the United States; PIPEDA, Canada's federal private-sector privacy law; and India's DPDPA, one of the most significant new privacy laws enacted anywhere in the world. Each defines its scope differently, assigns obligations to different parties, and creates a distinct set of individual rights.

Each framework reflects a different policy starting point. FERPA is institutional: it attaches to the type of records held by federally funded educational institutions. PIPEDA is consent-driven: it requires meaningful consent for private-sector personal data handling. India's DPDPA is comprehensive and extraterritorial, following a global trend toward GDPR-style data protection with local characteristics. Together, they illustrate that privacy compliance in cloud environments is never a one-jurisdiction question.

3. Core Concepts Explained

FERPA: Family Educational Rights and Privacy Act

Enacted in 1974 and administered by the US Department of Education, FERPA protects the privacy of student education records at institutions that receive federal funding. This covers virtually all public schools, community colleges, and universities in the United States. FERPA grants students and parents (for students under 18) the right to inspect and review education records, request corrections, and control disclosure to third parties.

Education records under FERPA include grades, transcripts, enrolment status, financial information, disciplinary records, and any records maintained by the institution directly related to a student. Personal notes kept by teachers for their own use and law enforcement records are excluded from the definition.

When an educational institution uses a third-party cloud platform to store or process student records, that vendor becomes a school official under FERPA. The institution must include contractual terms granting the vendor access only for legitimate educational purposes and restricting all other uses, including commercial advertising. The institution retains ownership and control of the records. Vendors that receive student data cannot use it for their own commercial purposes.

An important exam nuance: FERPA permits disclosure of directory information — student name, enrolment status, field of study, and degrees earned — without prior consent, unless the student has opted out. However, even directory information must be handled according to FERPA-compliant contract terms when a cloud vendor processes it.

PIPEDA: Personal Information Protection and Electronic Documents Act

PIPEDA governs the collection, use, and disclosure of personal information by private-sector organisations engaged in commercial activity in Canada, including inter-provincial and international data flows. It is built around ten Fair Information Principles: accountability, identifying purposes, consent, limiting collection, limiting use and disclosure and retention, accuracy, safeguards, openness, individual access, and challenging compliance.

Consent is PIPEDA's foundation. Organisations must obtain meaningful consent before collecting personal information. Consent must be informed: individuals must know what is being collected, why, and how it will be used. Express consent is required for sensitive information such as health data, financial records, or ethnic origin. Implied consent may be acceptable for less sensitive data when the purpose is obvious to a reasonable person.

The accountability principle is directly relevant to cloud deployments. An organisation is responsible for personal information transferred to a third-party processor, including a cloud provider. If the provider experiences a breach, the Canadian organisation remains accountable to PIPEDA. This responsibility cannot be shifted by contract. It means due

diligence in vendor selection, contract terms requiring equivalent safeguards, and ongoing monitoring are all PIPEDA obligations.

Several Canadian provinces have their own substantially similar privacy laws. Quebec's Law 25, modernised with phased implementation through 2021 to 2023, is the most stringent. It introduces mandatory Privacy Impact Assessments before certain data projects, required breach reporting to Quebec's Commission d'accès à l'information, and data minimisation and purpose limitation rules that closely parallel GDPR.

India's Digital Personal Data Protection Act (DPDPA)

Enacted in August 2023, India's DPDPA governs the processing of digital personal data of individuals in India, whether processing occurs inside or outside the country, if it relates to offering goods or services to Indian individuals. The Act uses distinctive terminology. The 'data fiduciary' is the organisation that determines the purpose and means of processing, analogous to GDPR's controller. The 'data principal' is the individual whose data is processed, analogous to GDPR's data subject.

Core obligations for data fiduciaries include: collecting data only for a lawful purpose with data principal consent; limiting collection to what is necessary; implementing reasonable security safeguards; notifying data principals of breaches; and erasing data when the purpose is fulfilled or consent is withdrawn.

Data principals hold rights including: the right to access information about their data; the right to correct or erase inaccurate data; the right to grievance redressal; and the right to nominate a representative to exercise rights in case of incapacity or death — a provision reflecting Indian cultural and legal traditions absent from GDPR.

Certain data fiduciaries are designated Significant Data Fiduciaries based on data volume, sensitivity, national security risk, and other factors. Significant Data Fiduciaries face additional obligations including appointment of a Data Protection Officer, periodic data protection impact assessments, and data audits. Cross-border transfers are permitted to government-approved countries, with India maintaining a list of restricted jurisdictions.

4. Comparative Framework Table

Dimension	FERPA (US)	PIPEDA (Canada)	DPDPA (India)
Scope trigger	Federally funded US educational institutions holding student records	Private-sector commercial activity in Canada	Processing digital personal data of individuals in India
Data type	Student education records	Personal information in commercial context	Digital personal data of any kind
Legal basis	Institution classification and federal funding	Consent (meaningful) or legitimate purpose	Consent or specific lawful basis
Cross-border	Vendor designated	Organisation	Permitted to

transfer	school official with contract	remains accountable; equivalent safeguards required	approved countries; restricted list published by government
Individual rights	Access, correction, consent before disclosure	Access, correction, withdrawal of consent	Access, correction, erasure, nomination, grievance redressal
Enforcement	US Dept of Education; loss of federal funding possible	Office of the Privacy Commissioner of Canada and courts	Data Protection Board of India; significant penalties

5. Real-World Incident

Case Study: In 2011, the US Department of Education's Student Privacy Policy Office investigated a major US school district after a vendor providing a cloud-based student assessment platform disclosed student performance data to a third-party marketing firm without authorisation. The vendor had accessed student records under a FERPA school official designation but used the data for a purpose outside legitimate educational interest: commercial advertising development. The district faced remediation requirements and the vendor lost its contract. The incident triggered a national policy discussion that led to student data privacy laws in over 30 US states and the Student Data Privacy Consortium model terms, now widely used as the basis for FERPA-compliant cloud vendor contracts in education.

6. Analogy

Think of FERPA, PIPEDA, and the DPDPA as three different keys to the same type of lock. The lock is protecting personal data. Each key has a different profile — FERPA is cut for student records at federally funded US schools, PIPEDA for private-sector commercial activity in Canada, and India's DPDPA for digital personal data about Indian residents globally. When your cloud deployment touches multiple jurisdictions, you may need all three keys simultaneously. Carrying only one does not open the others.

7. Exam Focus

FERPA, PIPEDA, and the DPDPA appear in CCSP exam scenarios requiring identification of the applicable law given a described organisation, data type, and geography. Key distinctions to hold in mind:

- FERPA applies to student education records at federally funded US educational institutions. It is not a general US personal data law.
- PIPEDA consent must be meaningful. Blanket or buried consent may not satisfy the standard for sensitive data.
- Quebec's Law 25 is stricter than federal PIPEDA and requires PIAs before certain new data projects.

- India's DPDPA uses data fiduciary for controller and data principal for data subject. These terms may appear directly in exam questions.
- Significant Data Fiduciaries under the DPDPA face additional obligations: DPO appointment, periodic DPIAs, and data audits.
- Under FERPA, a cloud vendor using student data for commercial purposes violates the school official designation even if the contract is otherwise in place.
- PIPEDA accountability means the Canadian organisation, not the cloud provider, remains responsible to Canadian regulators.

8. Key Terms Glossary

Education Records (FERPA): Records maintained by an institution directly related to a student, including grades, transcripts, and disciplinary files.

School Official (FERPA): A third-party vendor designated to handle student records for legitimate educational purposes under a FERPA-compliant contract.

Directory Information (FERPA): Student information disclosable without consent unless the student opts out, including name, enrolment status, and field of study.

PIPEDA: Canada's federal private-sector privacy law requiring meaningful consent for personal information collection, use, and disclosure in commercial activity.

Meaningful Consent (PIPEDA): Informed, voluntary consent appropriate to the sensitivity of the information and the nature of the proposed use.

Accountability Principle (PIPEDA): The obligation of a Canadian organisation to remain responsible for personal data even after it is transferred to a third-party processor.

Data Fiduciary (DPDPA): The organisation or individual that determines the purpose and means of processing personal data under India's DPDPA.

Data Principal (DPDPA): The individual whose personal data is being processed under India's DPDPA.

Significant Data Fiduciary (DPDPA): A data fiduciary subject to enhanced obligations under the DPDPA based on data volume, sensitivity, or national security considerations.

Law 25 (Quebec): Quebec's modernised privacy law requiring PIAs, real-time breach reporting to the CAI, and enhanced consent standards for organisations operating in Quebec.

9. Quick Revision Checklist

- ☐ I can state the data category and institution type that triggers FERPA.
- ☐ I know that cloud vendors handling student records must be designated school officials with FERPA-compliant contract terms.

- ☐ I understand that FERPA prohibits vendors from using student data for commercial purposes outside the educational context.
- ☐ I can describe PIPEDA's consent principle and explain what meaningful consent requires.
- ☐ I know that PIPEDA's accountability principle means the Canadian organisation remains responsible even when data is at a foreign cloud provider.
- ☐ I can distinguish Quebec's Law 25 from federal PIPEDA and identify its additional requirements.
- ☐ I know that India's DPDPA uses data fiduciary for controller and data principal for data subject.
- ☐ I can state the additional obligations placed on Significant Data Fiduciaries under India's DPDPA.
- ☐ I recognise that all three frameworks grant individuals rights of access and correction over their personal data.
- ☐ I can identify which law applies given a scenario describing the data type, institution type, and jurisdiction.

10. Practice MCQs

Question 1

SCENARIO: A large US public university migrates its student information system to a cloud platform provided by a technology company in Ireland. Student records include grades, financial aid details, and disciplinary records. The university receives federal Title IV funding. Which statement correctly describes the cloud vendor's obligations under FERPA?

A) The vendor is not subject to FERPA because it is headquartered outside the United States.

Explanation: Incorrect. FERPA obligations follow the data, not the vendor's country of incorporation. Once designated as a school official, the vendor is bound by FERPA regardless of location.

B) The vendor must be contractually designated as a school official with legitimate educational interest and may not use student data for commercial purposes.

Explanation: Correct. Under FERPA, a cloud vendor receiving student records must be designated as a school official with legitimate educational interests, subject to restrictions on use and commercial exploitation.

C) The vendor is only required to comply with Irish data protection law, which supersedes FERPA.

Explanation: Incorrect. FERPA governs the university's obligations as a US-funded institution. Both GDPR and FERPA may apply simultaneously; neither supersedes the other.

D) The vendor is exempt because financial aid records are excluded from FERPA's definition of education records.

Explanation: Incorrect. Financial aid records are explicitly included in FERPA's definition of education records when maintained by the institution.

Question 2

SCENARIO: A Canadian e-commerce company collects customer purchase history, email addresses, and browsing behaviour through its cloud-hosted platform. It wants to use this data for personalised advertising without obtaining additional consent beyond the original checkout agreement. Which PIPEDA principle is most directly at risk?

A) Accuracy — browsing data may not accurately represent customer intent.

Explanation: Incorrect. The accuracy principle concerns keeping data up to date. The scenario describes a consent and purpose limitation issue.

B) Consent and limiting use — using data for advertising beyond the stated checkout purpose requires separate meaningful consent.

Explanation: Correct. PIPEDA requires consent for each new purpose. Using purchase data for personalised advertising represents a new purpose not covered by the original checkout consent.

C) Openness — the company should publish its advertising practices in a publicly accessible policy.

Explanation: Incorrect. Publishing a policy satisfies openness but does not substitute for obtaining consent for a new use of personal data.

D) Safeguards — the company must protect browsing data with encryption and access controls.

Explanation: Incorrect. The safeguards principle governs security. The scenario presents a consent and purpose limitation issue, not a security gap.

Question 3

SCENARIO: A multinational cloud services company processes personal data of Indian residents on behalf of an e-commerce platform designated as a Significant Data Fiduciary under India's DPDPA. Which obligation applies to the e-commerce platform but not to the cloud company in its processor capacity?

A) Implementing reasonable security safeguards for personal data.

Explanation: Incorrect. Both data fiduciaries and processors must implement appropriate security safeguards under the DPDPA.

B) Conducting periodic data protection impact assessments and appointing a Data Protection Officer.

Explanation: Correct. Significant Data Fiduciary obligations including DPIAs and DPO appointment apply to the data fiduciary. Processors are required to process only as directed and maintain security, but do not carry Significant Data Fiduciary-specific enhanced obligations.

C) Notifying data principals in the event of a personal data breach.

Explanation: Incorrect. Breach notification to data principals is a data fiduciary obligation. However, the processor's duty to inform the fiduciary enables the fiduciary to meet its own obligation. The question asks about obligations solely on the fiduciary.

D) Processing data only for the purposes specified in the contract with the fiduciary.

Explanation: Incorrect. This is a processor obligation, not a Significant Data Fiduciary-specific obligation.

Question 4

Under FERPA, which of the following represents directory information that may generally be disclosed without prior student consent?

A) Grade point average and academic performance records.

Explanation: Incorrect. Academic performance records are explicitly protected education records under FERPA and require consent before disclosure.

B) Financial aid award amounts and scholarship details.

Explanation: Incorrect. Financial aid information is a protected education record, not directory information.

C) Student name, enrolment status, and field of study.

Explanation: Correct. FERPA permits institutions to designate categories such as name, enrolment status, field of study, and degrees earned as directory information, disclosable without consent unless the student opts out.

D) Disciplinary records and academic probation status.

Explanation: Incorrect. Disciplinary records are protected education records requiring consent for disclosure.

Question 5

A Canadian financial services firm transfers customer personal data to a US cloud provider. The provider experiences a breach and customer records are exposed. Under PIPEDA, which statement best describes the Canadian firm's accountability?

A) The Canadian firm's obligation ends when it transfers data to the US provider; the provider is responsible under US law.

Explanation: Incorrect. PIPEDA's accountability principle explicitly places responsibility on the Canadian organisation for data transferred to processors. The transfer does not shift accountability.

B) The Canadian firm remains accountable to PIPEDA for protecting data at the cloud provider and must report the breach to the OPC.

Explanation: Correct. Under PIPEDA's accountability principle and the Breach of Security Safeguards Regulations, the Canadian firm is responsible for data at processors and must report material breaches to the Office of the Privacy Commissioner.

C) The Canadian firm has no reporting obligation unless the breach affected Canadian government employees.

Explanation: Incorrect. PIPEDA's breach reporting requirements apply broadly to private-sector organisations. They are not limited to government employee data.

D) The Canadian firm must cease all transfers to the United States until PIPEDA is amended.

Explanation: Incorrect. PIPEDA does not prohibit cross-border transfers. It requires equivalent safeguards and accountability — not cessation of transfers.

Question 6

India's DPDPA includes a right not present in GDPR that reflects Indian cultural and legal tradition. Which right is this?

A) Right to data portability.

Explanation: Incorrect. Data portability is a GDPR right. India's DPDPA does not include an equivalent portability right in its current form.

B) Right to nominate a representative to exercise data rights in case of incapacity or death.

Explanation: Correct. The DPDPA includes a right of nomination allowing data principals to designate another person to exercise their rights if they die or become incapacitated. This reflects Indian legal traditions and is absent from GDPR.

C) Right to opt out of automated decision-making without human intervention.

Explanation: Incorrect. GDPR Article 22 addresses automated decision-making. India's DPDPA does not include an equivalent provision in its current text.

D) Right to restrict processing pending consent renewal.

Explanation: Incorrect. Restriction of processing in this form is a GDPR right. The DPDPA's individual rights framework does not include a direct equivalent.

Question 7

Which of the following best describes the relationship between PIPEDA and Quebec's Law 25?

A) Law 25 is a subset of PIPEDA and imposes fewer obligations for organisations in Quebec.

Explanation: Incorrect. Law 25 is widely regarded as more stringent than PIPEDA, with additional requirements including mandatory PIAs and enhanced breach reporting to the CAI.

B) Law 25 applies to organisations in Quebec for intra-provincial matters and imposes additional requirements beyond PIPEDA.

Explanation: Correct. Quebec's Law 25 is recognised as substantially similar to PIPEDA for federal-provincial purposes but applies for intra-provincial matters and introduces additional obligations including PIAs, real-time breach reporting, and enhanced consent standards.

C) PIPEDA supersedes Law 25 when a Quebec company operates nationally.

Explanation: Incorrect. For intra-provincial matters, Law 25 applies where it has been recognised as substantially similar. Organisations with both intra-provincial and inter-provincial activity may be subject to both.

D) Law 25 applies only to public-sector organisations in Quebec.

Explanation: Incorrect. Law 25 applies to private-sector organisations in Quebec. Public-sector entities in Quebec are governed by separate provincial legislation.

Question 8

An educational technology company provides a cloud learning management system to a US community college under a FERPA school official designation. The company's marketing team proposes using student login frequency data to build a commercial product for other institutions. What is the most accurate assessment?

A) Acceptable because login frequency is not a protected education record.

Explanation: Incorrect. Login frequency data in an institution's system is part of the student record maintained by the institution and is covered by FERPA as it directly relates to enrolled students.

B) Acceptable if the company anonymises the data before commercial use.

Explanation: Incorrect. While anonymisation can take data outside FERPA's scope, the school official designation restricts use regardless of anonymisation. Using student data to develop a commercial product requires explicit institutional authorisation beyond the standard school official terms.

C) A violation of FERPA because the school official designation prohibits using student data for purposes outside legitimate educational interests.

Explanation: Correct. The school official designation grants access only for purposes serving the institution's legitimate educational interests. Developing a commercial product for sale to other institutions falls outside that purpose and constitutes a FERPA violation.

D) Permissible if the college provides written notice to enrolled students.

Explanation: Incorrect. Student notice does not authorise a use outside the scope of the school official relationship. The college cannot unilaterally expand vendor permissions through notice without revising contractual terms and potentially obtaining student consent.

Question 9

Under India's DPDPA, when does a data fiduciary's obligation to retain personal data end?

A) After seven years from initial collection, regardless of purpose.

Explanation: Incorrect. The DPDPA does not establish a universal seven-year retention period. Retention duration depends on the stated purpose.

B) When the purpose for collection is fulfilled or the data principal withdraws consent.

Explanation: Correct. The DPDPA requires data fiduciaries to erase personal data when it is no longer needed for the stated purpose or when the data principal withdraws consent and there is no overriding legal basis for continued retention.

C) When the data principal reaches age 18, regardless of context.

Explanation: Incorrect. The DPDPA includes special provisions for processing children's data, but the general retention obligation is tied to purpose fulfillment, not the data principal's age.

D) When the data processor notifies the fiduciary that processing is complete.

Explanation: Incorrect. Processor notification is not the trigger for the data fiduciary's retention obligation. The fiduciary determines when the purpose is fulfilled or consent is withdrawn.

Question 10

SCENARIO: A cloud-hosted platform processes student transcripts for a US state university, customer financial data for a Canadian insurance company, and application data for Indian mobile users. Which mapping correctly identifies the primary applicable privacy framework for each?

A) All three are governed by GDPR as it is the most comprehensive global privacy law.

Explanation: Incorrect. GDPR applies to EU residents' personal data. None of the three categories described primarily involve EU residents as a defined trigger.

B) Student transcripts: FERPA; Canadian financial data: PIPEDA; Indian mobile user data: India's DPDPA.

Explanation: Correct. FERPA governs student education records at federally funded US institutions. PIPEDA governs private-sector commercial personal data in Canada. India's DPDPA governs digital personal data of Indian residents. Each framework is triggered by the specific combination of data type, institution type, and individual location described.

C) Student transcripts: HIPAA; Canadian financial data: FERPA; Indian mobile user data: PIPEDA.

Explanation: Incorrect. HIPAA governs health information at covered entities, not academic records. FERPA is a US law and does not govern Canadian financial data. PIPEDA governs Canadian commercial data, not Indian mobile users.

D) All three are governed by PIPEDA because processing occurs in a cloud environment.

Explanation: Incorrect. The cloud environment does not determine jurisdictional applicability. Each framework is triggered by specific criteria unrelated to the use of cloud infrastructure.